Strategy for Implementing of Zero Trust Architecture

Mengru Tsai, Shanhsin Lee, and Shiuhpyng Winston Shieh, *Fellow, IEEE*

***Abstract*—In recent years, due to the impact of the COVID-19 pandemic, enterprises have been forced to adapt their operation patterns to ensure resilience, transitioning from traditional office-based work to remote work from home. However, this sudden and unforeseen change has made enterprises unprepared, resulting in a dramatic increase in cybersecurity threats. The most significant challenge arises from the adjustment from working in previously trusted areas to that beyond the boundaries of protection. While employees used to work within the company's defense perimeter, malicious attacks were blocked and detected by boundary security gateways. Shifting to remote work moves employees out of the protective environment, thereby their devices connecting to the internal resources of a company become exploitable targets for threat actors, and weaknesses in the internal authentication, authorization, and access control mechanisms become evident. The zero trust architecture (ZTA) approach is primarily focused on resource protection. When users or services attempt to access resources, ZTA requires precise authentication, minimal authorization, and continuous verification (trust inference) to ensure legitimacy and authorization of the resource usage, eliminating any space for assumed or inherited trust. In this article, we will address the challenges in handling the threats and propose the strategies, implementation, and limitation of ZTA, aiming to shed light on its effectiveness and applicability in mitigating cybersecurity risks.**

***Index Terms*—Attribute-based access control (ABAC), function-based access control (FBAC), MITRE ATT&CK matrix, policy decision point (PDP), policy enforcement point (PEP), role-based access control (RBAC), zero trust architecture.**

I. Cybersecurity Threats Conundrum

IN RECENT years, the global outbreak of COVID-19 has significantly altered our way of life and work. Governments worldwide have implemented isolation policies to curb the spread of the virus, leading to reduced human interactions. As a result, many businesses faced operational challenges, prompting them to swiftly switch from traditional office-based work to remote work from home [1]. This remote work model offered greater flexibility and convenience, allowing employees to work from the comfort of their homes while minimizing the risk of face-to-face contact.

However, this sudden transformation also introduced new cybersecurity dilemmas. Many enterprises struggled to promptly adapt to these changes, resulting in a drastic surge in cybersecurity threats. The most significant issue stemmed from the relocation of previously trusted areas to those beyond protective boundaries. In a conventional cybersecurity defense scenario, employees worked within the company's secure perimeter, where attacks could be detected and blocked by boundary security devices. However, once employees leave the protected environment and use their devices to access company resources, the absence of robust cybersecurity measures makes them vulnerable targets for hackers. This exposes the company's internal resources to the reach of potential attackers, highlighting weaknesses in the authentication and verification mechanisms of internal system services.

In response to these challenges, the zero trust architecture (ZTA) emerged as a viable solution. Its core objective is comprehensive resource protection, requiring precise authentication and minimal authorization when users or assets attempt to access resources. In addition, continuous verification (trust inference) is enforced during resource usage to ensure its legality and legitimacy, leaving no room for implicit or inherited trust. Such a security framework empowers enterprises with greater security measures, demanding strict authorization procedures even for internal system services' access.

Moreover, under the framework of ZTA, the management of internal systems and services' information security environment can be strengthened. If any internal services are compromised, this robust management framework can mitigate the extent of the breach's impact.

Also, a persistent challenge lies in the ongoing battle between information security defenders and adversarial actors that attempt to exploit vulnerabilities or resort to social engineering techniques. Despite continuous advancements in security measures and threat detection technology, cyber threats continue to evolve in complexity, scale, and sophistication. However, the ZTA also has its limitations, as this article will explore. As hacking techniques become increasingly sophisticated and attack patterns grow increasingly similar to normal behavior, these are among the problems that ZTA cannot fully address.

II. Zero Trust Architecture

In the NIST SP 800-207 document [2], the ZTA focuses on resource protection, where implicit and inherited trust is never granted, and granted authorizations must be continuously evaluated. The core ZTA is divided into two main components: the policy decision point (PDP) running in the control panel (upper half in Fig. 1) and the policy enforcement point (PEP) running in the data panel (lower half in Fig. 1). The PDP serves as the "brain" of the ZTA, governing the authorization of all

Manuscript received 4 December 2023; revised 13 December 2023; accepted 16 December 2023. Date of publication 5 January 2024; date of current version 5 March 2024. This work was supported in part by the Taiwan National Science and Technology Council, and in part by the Woodpecker Technology Inc. Associate Editor: J. W. Rupe. *(Corresponding author: Shiuhpyng Winston Shieh.)*

The authors are with the Department of Computer Science, National Yang Ming Chiao Tung University, Hsinchu 30010, Taiwan (e-mail: mengru.tsai.c@nycu.edu.tw; shlee.c@nycu.edu.tw; ssp@nycu.edu.tw).

Digital Object Identifier 10.1109/TR.2023.3345665

1558-1721 © 2024 IEEE. Personal use is permitted, but republication/redistribution requires IEEE permission.
See https://www.ieee.org/publications/rights/index.html for more information.

Authorized licensed use limited to: Sheffield University. Downloaded on March 26,2026 at 05:53:57 UTC from IEEE Xplore. Restrictions apply.

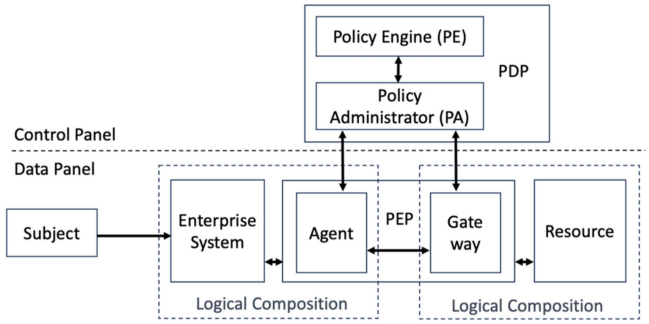

Fig. 1. Logical core structure of the ZTA.

subjects (including end-users, nonhuman entities, and applications) to access enterprise resources. On the other hand, the PEP follows the rules provided by the PDP to establish and terminate connections (with time constraints and varying connection times due to different enterprise environmental factors and security policies). The connections should be continuously monitored and may be blocked based on threat intelligence and internal analysis, following trust inference requests from the PDP to the PEP.

In summary, the entire process of subjects accessing resources is protected by a secure defense "bubble" created by ZTA, where implicit trust is eliminated, and the authorization process is strictly controlled and monitored. The defense "bubble" is time-limited, and when the specified time is up, protection is deactivated. The logical core structure of the ZTA shown in Fig. 1 includes the following components.

A. Policy Decision Point, PDP

Within the PDP, there are two key components: the policy engine (PE) and the policy administrator (PA). The PE is responsible for authorizing the rules, which are configured based on internal enterprise settings, security log records, and external threat intelligence. These rules are used to establish time-limited security barriers between subjects and resources, thereby creating a secure environment for the use of these resources.

On the other hand, the PA operates based on the rules provided by the PE. If a session between a subject and a resource requires authorization and authentication, the PA will send signals or commands to the relevant PEP. The PEP is then notified to either establish or terminate the subject-resource connection accordingly. This mechanism ensures that all connections are properly authorized and continuously monitored by the PDP, allowing for dynamic and secure access control within the ZTA.

B. Policy Enforcement Point, PEP

The PEP is responsible for initiating, monitoring, and terminating the connections between subjects and resources. In its logical architecture, the PEP can be divided into two parts: agent and gateway. The agent is deployed (installed) in the enterprise system (client devices within the enterprise), while the gateway is positioned in front of the enterprise system's resource devices.

When a subject initiates a connection request to a specific enterprise resource, the enterprise system sends the connection request to the PA through the agent. The PA then forwards the request to the PEP for evaluation and authorization. After granting the authorization, the PA establishes a communication channel between the subject and the resource and sends signals (commands) to the agent and gateway to establish the connection.

If the PEP detects or obtains any suspicious information or security issues during the connection, it will send a termination signal to the agent and gateway through the PA. Consequently, the connection is terminated between agent and gateway immediately. This dynamic process ensures that all connections are continuously monitored and controlled within the ZTA, providing a secure and responsive access control mechanism (see Fig. 1).

C. Cybersecurity Logs

In addition to the core components of PDP and PEP, there are several other important aspects, including cybersecurity logs, threat intelligence, the norm of authorization, and device and identity identification.

Cybersecurity logs involves providing information about the system status and log records of various internal systems within the enterprise, including user devices, enterprise service devices, firewalls, and intrusion prevention devices located within the boundary defenses. These logs include device compliance and activity logs, which are aggregated into a security information and event management (SIEM) system. The information in the SIEM system serves as a reference resource for authorization judgments made by the PDP. Device compliance includes details such as the operating system version, software inventory, operating system and software update status, presence of personal firewalls, and the installation of security control software like endpoint detection and response (EDR)/network detection and response (NDR)/extended detection and response (XDR). In addition, the determination whether a device belongs to the enterprise's internal assets can be monitored by NDR and confirmed by using trusted platform module (TPM) [3] utilization and verification checks.

D. Threat Intelligence

Threat intelligence refers to the reception of information from internal or external sources about network attack incidents and vulnerabilities. This information serves as a reference for the PDP when making authorization decisions. For example, if the PDP receives external threat intelligence indicating a known attacker's IP address attempting to establish a connection to enterprise internal system resources, the PEP will be notified by the PA to block such access through a signaling command.

Furthermore, when an enterprise faces a network attack, event analysis can provide details about the characteristics of the attack. Through this information-sharing model with external organizations, a more comprehensive, collective defense approach can be established to better protect against future threats.

Authorized licensed use limited to: Sheffield University. Downloaded on March 26,2026 at 05:53:57 UTC from IEEE Xplore. Restrictions apply.

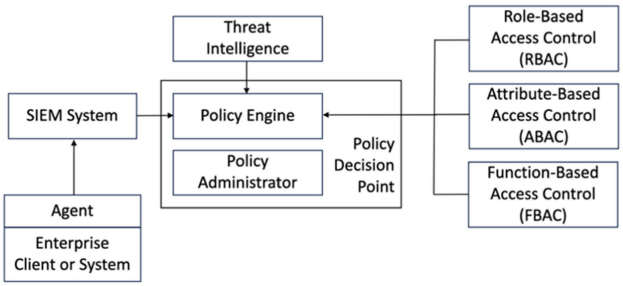

Fig. 2. PDP logic flow diagram.

E. Norm of Authorization

In the ZTA, the procedure of authorized establishment is the core aspect of granting subjects access to internal resources. The configuration of permissions can be classified into three main types based on requirements and functionalities: role-based access control (RBAC), attribute-based access control (ABAC), and function-based access control (FBAC). The interaction and relationship between these three components and PDP are illustrated in Fig. 2.

RBAC [4] is the most commonly used and prevalent permission assignment model in enterprises. In this approach, permissions are configured based on roles, and users are assigned roles accordant with their nature of work. Once a role is assigned, the user is given the same permissions as that role. The advantage of RBAC is that it simplifies the process of configuring different roles' permissions and allows for easy scalability based on the organizational structure of the roles. However, a notable drawback is that in large and diverse organizations, RBAC can become difficult to manage. In addition, RBAC lacks granularity in setting access permissions, making it challenging to adjust for more specific permissions, such as granting access based on specific time frames.

ABAC is a permission assignment model based on attributes, which captures contextual information from different devices and system environments within the enterprise [5]. It offers greater scalability and finer granularity in access control settings compared to RBAC. In ABAC, attributes can be related to users, resources, environments, or even application states [6], for example, allowing all employees in the finance department to access the payment system during working hours. While ABAC enables better access control configurations, defining ABAC rules can be challenging and prone to rule conflicts. It requires considerable time for fine-tuning, adjustment, and testing to be effectively implemented within an enterprise.

Both RBAC and ABAC access control approaches are well-explained and implemented in [6], which compares factors such as flexibility, simplicity, granularity, dynamic decisions and rules, context-awareness, and implementation efforts for RBAC, ABAC, and hybrid models. In addition, there is a less common access control model known as FBAC, described as follows.

FBAC [7] is, as the name suggests, an access control approach that focuses on granting permissions based on specific functionality. It differs from ABAC and RBAC by providing an additional layer of access control, allowing for more fine-grained control over access based on the functions performed. For example, in a Linux environment, FBAC can be used to regulate the usage of the "grep" command (and not limited to just this command) by defining permissions for users on what type of files they can execute "grep" on, including optional parameters within the command. In this access control configuration mode, we can extend it to interfaces such as instructions and application programming interfaces (APIs) for a more comprehensive access permission setup.

F. Device and Identity Identification

In enterprises, users' devices (including personal computers, laptops, or mobile devices) are often the most challenging to secure, as they can become vulnerable to cybersecurity breaches due to momentary lapses or negligence. In poorly managed cybersecurity environments, devices are frequently exploited, hijacked, or impersonated by malicious actors to facilitate infiltration and data theft. Therefore, identifying enterprise devices has become critically important.

Device identification serves the primary purpose of confirming the assets within an enterprise, excluding devices that do not belong to the organization. All devices must undergo device identification, and the identification process may use the TPM which is an international standard for cryptographic processors [8], designed to use dedicated security hardware (chip) integrated into the device to handle encryption keys. By utilizing an agent installed within the asset, TPM is used for device identification, ensuring that the device belongs to the enterprise's assets. In cases where a device does not support TPM, alternative methods can be employed via the agent to confirm the device asset; however, this process may be weaker in terms of strength compared to using TPM for device identification.

Identity identification, in addition to identifying devices, is another crucial aspect to authenticate user identities. As with identifying internal assets, operators must also be members of the organization or authorized personnel. Identity authentication can be implemented using multifactor authentication (MFA) and can be combined with biometric features for identity verification.

To execute identity authentication, the enterprise must establish an identity management system, which works in conjunction with the aforementioned multifactor methods for verification. If the enterprise has a public key infrastructure (PKI), it can leverage this framework to enhance identity authentication strength, and to provide a more secure environment. Alternatively, a simpler approach like Fido2 may be used for identification. Utilizing Fido2 to construct identity authentication incurs lower costs than establishing a complete PKI, making it a more practical choice that significantly reduces the costs associated with implementing a zero-trust framework within the enterprise.

III. Cyclic Zero Trust Architecture

In this article, we approach the ZTA from a more comprehensive perspective. We integrate elements from NIST SP 800-207 documentation, [9], and all the parts related to zero trust as discussed in the articles referenced in this article. We describe their interrelationships with each other and will create a diagram

Authorized licensed use limited to: Sheffield University. Downloaded on March 26,2026 at 05:53:57 UTC from IEEE Xplore. Restrictions apply.

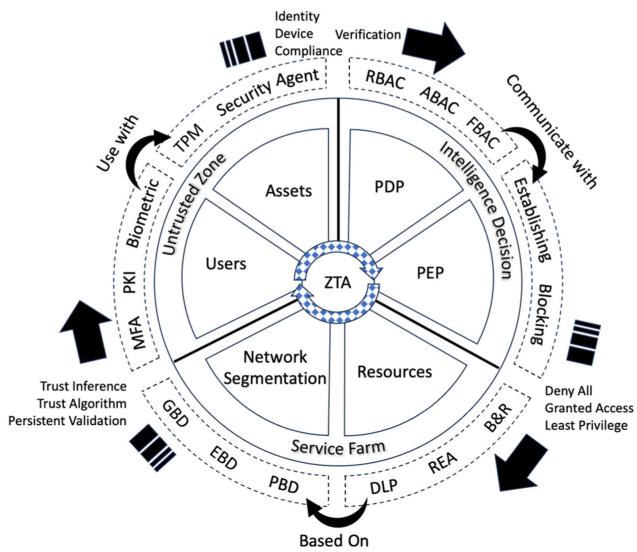

Fig. 3. Cyclic zero trust architecture.

similar to Fig. 3. In this diagram, the entire zero trust operational workflow begins with users and proceeds in a clockwise direction, gradually completing zero trust verification, authorization, and resource access.

The core area of the diagram is divided into three parts. The first part is the untrusted zone, the second part is the intelligence decision, and the third part is the service farm. Each area's transition behaviors are briefly described at the outermost edges of the arrows where they meet at their boundaries. The methods or means to achieve zero trust, corresponding to objects within the fan-shaped areas (e.g., users in the untrusted zone or PDP in intelligence decision), are described in the peripheral dashed area (users corresponding to MFA, PKI, and biometric, and PDP corresponding to RBAC, ABAC, FBAC). We will now explain each part progressively, starting from the central area and then moving outward.

A. Untrusted Zone

In this area, no matter within or outside the organization, all users and assets are considered untrusted even for individuals known to the organization. Before accessing resources, identity authentication and asset verification must be completed. Continuous diagnostics are necessary to ensure that, at the moment of authentication, not only is the user genuinely who they claim to be, but also the assets are also compliant with organizational policies and requirements.

Compliance ensures that assets are accessed in accordance with organizational policy principles. This includes verifying the presence and continuous operation of antivirus software, personal firewalls, and security agents (EDR, NDR, XDR). In addition, during each login authentication, it ensures the verification of up-to-date antivirus and operating systems, adherence to organizational configurations for personal firewalls, and the proper activation and monitoring of security agents as organizational requirements. Below, we will explain the methods and means that can be adopted for users and assets in the untrusted zone area.

MFA [10] is a method of using multiple authentication factors to identify and verify users. Traditional usernames and passwords are insufficient to confirm a user's identity. Once usernames and passwords are compromised, the user's identity can be potentially impersonated. Therefore, when verifying user identities, the principles of "What you know," "What you have," and "What you are" are used to ensure an irreplaceable user identity. "What you know" refers to a PIN code or password. In the MFA mechanism, "What you know" cannot exist as the sole authentication process; it must be combined with "What you have" or "What you are." "What you have" means something you own outside of yourself, which includes trusted devices or smart cards, such as Fido2 devices [11] and passkey devices [12]. "What you are" pertains to biometric features, such as facial recognition, fingerprints, or irises.

PKI [13] is a comprehensive digital certificate ecosystem management mechanism. It involves digital certificates issued by organizations and integrated into smart cards (or other devices capable of storing private key certificates in secure areas on a chip). This not only verifies the authenticity of certificates held by users as being issued by the organization but also confirms the unique identity of the user through a public–private key mechanism. Considering the cost and necessity of building a PKI infrastructure, the majority of organizations do not establish their own PKI and may opt for devices like Fido2 or passkey devices as alternatives.

Biometrics are a means to ascertain user identity and are one of the most commonly used mechanisms for identity verification in a ZTA. Their primary appeal lies in providing irreplaceability of user identity. Biometrics include fingerprints, facial recognition, irises, and more.

TPM [3], [14] primarily aims to address the issue of asset verification. In a ZTA, just like user verification, assets must also undergo a similar level of verification. However, assets cannot, as part of the verification process, insert additional devices or use biometrics for identity confirmation as users do. Nonetheless, assets can also utilize TPM to undergo a verification process similar to that of users. TPM is a hardware-level module embedded in the motherboard. It can store sensitive information such as user credentials, certificates, encryption keys, and offers hardware-level security protection. When integrated into the motherboard, TPM enables asset verification and identification. By using the private key stored in TPM, asset devices are identified to confirm that they belong to the organization's assets.

A *security agent* is software installed on asset devices. Its primary purpose is to enforce restrictions (such as prohibiting the use of USB devices) and monitor the devices. Typically, in larger organizations, employees are not allowed to freely install or connect any devices to assets to prevent the unauthorized extraction of sensitive internal information within an uncontrolled environment. Therefore, restrictions or disabling must be implemented through security agents installed on the assets.

Security agents continuously monitor the health of the devices. This includes checking if the operating system and installed software on assets are up-to-date, ensuring that personal

Authorized licensed use limited to: Sheffield University. Downloaded on March 26,2026 at 05:53:57 UTC from IEEE Xplore. Restrictions apply.

firewalls are configured according to organizational policies, and verifying the proper operation of antivirus and completion of virus definition updates. When users authenticate through asset, it is important to ensure compliance with these requirements. Any noncompliance triggers alerts or denies subsequent user authentication operations. Furthermore, organizations must confirm the software programs installed on asset devices. For example, in the event of a common vulnerabilities and exposures notification involved the software vulnerabilities of a device in an organization, the organization can take preventive measures in advance.

B. Intelligence Decision

The intelligence decision part includes the PDP and PEP. The PDP serves as the core of the entire ZTA authentication and verification processes. It encompasses the design and plan of user permissions granted by the organization, including RBAC, ABAC, and FBAC, as well as threat intelligence and log data collected within the organization (SIEM). Through these three components, permissions for user access requests to resources can be rigorously granted. On the other hand, the PEP establishes communication links for users and resources, creating isolated connection channels based on the destination of the user's requests. When the PDP receives threat intelligence about a user or alerts from the SIEM, the PEP immediately terminates the user's connection service.

In the ZTA, access permissions for resources are set based on the principle of least privilege, and there is no default trust or inherited trust. All aspects of user access must go through the PDP for processing and granting. Detailed information regarding the Intelligence Decision has been explained in Session II and will not be elaborated further in this section.

C. Service Farm

Due to the ZTA, resources are no longer confined to hardware servers. In this article, we replace the term "Server Farm" with "Service Farm." In this section, we delve into two aspects: resource and network segmentation. Resource deployment is based on network segmentation, primarily aiming to safeguard each resource and prevent lateral expansion to other resource services in case a resource is compromised. In conventional DMZ configurations, such lateral infections among compromised resource services are common. Here, we explore the approaches and methods that can be adopted for both the resources and network segmentation within the context of ZTA.

Backup and recovery (B&R) is not only essential in a ZTA but also in any enterprise or organization that provides services. Backup is one of the fundamental means for disaster recovery. It ensures that resources and services can be restored to their state at the time of the backup in the event of a disaster. This depends on the density of backups. The more frequent the backups are performed, the greater the impact on the organization's storage space will be. Incremental backups are often used to address this issue.

The robust encryption algorithm (REA) is the most direct means of resource transmission protection. By "robust," we mean that it does not include any deprecated encryption algorithms at the current state-of-the-art technological level. Excluding these deprecated encryption algorithms is essential because they pose a risk of being decrypted. In addition, if hash algorithms lack robustness, they can also pose data collision risks. Therefore, REAs are necessary for data protection within the ZTA. Furthermore, with the emergence of quantum computing (even though it is still in ongoing development), the risks associated with breaking current encryption algorithms have significantly increased. In response to this issue, in 2022, NIST selected public-key encryption, key-establishment algorithms, and digital signature algorithms from postquantum cryptography [15] to counter quantum decryption.

Data loss prevention (DLP) is a technology designed to prevent data leaks. Endpoint data protection software can monitor and safeguard data on assets, protecting it from accidental or malicious data leakage [16]. Once users are authenticated and authorized, they are allowed to access data resources. However, this data must be protected to a certain degree, and DLP is effective for data leakage prevention.

Gateway-based deployment (GBD) [17] is a mechanism that distinguishes between user access to assets installed with agents on asset and gateways preloaded in front of organizational resources. The operation mode of these two parts is the same as the PEP processing mechanism discussed earlier. The operational process is as follows. When a user working on an organizational asset sends an access request to resources, the request will be sent to the PDP through the agent (part of the PEP). The PDP analyzes and decides whether the request complies with the organization's policies. Simultaneously, the PDP notifies the gateway in front of the resource and establishes a connection tunnel through the gateway between the two sides. At this point, the granted request can be transmitted to the gateway, and the data can be retrieved from the resource to the user's asset.

In this setup, a gateway is installed in front of each resource, and each gateway is responsible for controlling access requests to the resources behind it. Each gateway must go through the PDP's approval and establish connections tunnel through the PEP before handling network requests. When a resource experiences an incident or is compromised, the compromised resource cannot easily propagate lateral infections. While GBD can provide excellent security control and protection, it also represents a substantial burden for organizations.

Enclave-based deployment (EBD) [17] is similar to the configuration of the GBD structure. However, in the case of EBD, gateways are responsible for managing several micro services. Typically, EBD and GBD are used in combination. More complex or logically intricate resources are designed using the GBD approach, where each resource is managed by an individual gateway. On the other hand, resources with simpler logic or single-service resources are deployed by using EBD.

Portal-based deployment (PBD) [17] features a unique deployment architecture: it does not require the installation of agents on the user's asset devices. Instead, all access requests to resources are directed to a portal. After validation and authorization by the PDP, the portal processes the user's resource request. However, as no agents are installed on the user's asset devices,

Authorized licensed use limited to: Sheffield University. Downloaded on March 26,2026 at 05:53:57 UTC from IEEE Xplore. Restrictions apply.

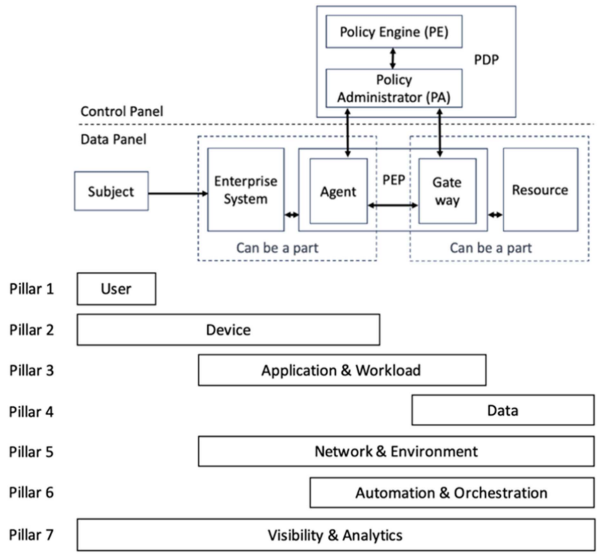

Fig. 4. Seven pillars potentially covered by the ZTA scope.

it raises concerns about the compliance status of these assets with organizational regulations. In addition, in this architecture, the portal may become a target for DDoS attacks by hackers. A single point of failure in the portal can disrupt all of the organization's services.

IV. Implementation of Zero Trust Architecture

The implementation of the zero-trust framework largely follows the components mentioned earlier, such as establishing the PDP, PEP, and implementing device and identity recognition mechanisms, among others. In this section, we will refer to the U.S. Department of Defense's Zero Trust Strategy document [17] for an introduction. This document provides comprehensive guidelines and means for implementing zero-trust principles and clearly distinguishes between well-defined architectures that facilitate the adoption of internal zero-trust technologies.

In the U.S. Department of Defense Zero Trust Strategy document, it emphasizes that the realization of zero-trust capabilities can begin with the seven pillars shown in Fig. 4. These seven pillars encompass the complete spectrum of our enterprise's security measures, namely user, devices, applications and workloads, data, network and environment, automation and orchestration, and visibility & analytics.

A. User Capability

User capability in the ZTA framework involves continuously verifying, accessing, and monitoring user activities to ensure that the enterprise can actively control and confirm the legitimacy of users. All user-related records generated here are collected through SIEM for further analysis. The implementation of this capability includes creating a user list and using this data to verify that they belong to the personnel of the enterprise. Apart from establishing the list, it also covers conditional user access, MFA, privileged access management, identity federation & user credentialing, "behavioral, contextual ID, and biometrics," least privileged access, and continuous authentication. In total, there are nine capabilities within this pillar.

B. Device Capability

Devices capability focuses on monitoring the health of enterprise devices, including checking whether they are listed in the controlled device inventory, or comply with the organization's cybersecurity standards (such as having up-to-date software and approved software installations). It also involves deploying unified endpoint management (UEM), mobile device management (MDM), EDR & XDR software, etc. These control measures need to be checked, evaluated, and monitored in real-time for every access request. In the document [17], the device capability includes device inventory, device detection and compliance, device authorization with real-time inspection, remote access, partial & fully automated asset, vulnerability and patch management, and UEM & MDM, and EDR & XDR.

C. Application & Workload Capability

After protecting users and devices, the next step is to focus on comprehensive protection for application services. Application services include applications, containers that host them, and virtual machines. Similar to the users and devices capability, it is essential to create an application inventory, establish a secure software development integration process, and integrate continuous integration and continuous delivery processes. Throughout the software construction and implementation process, robust risk management practices should be in place, and various available automation tools can be used to continuously monitor applications and assess their authorization validity in real-time.

D. Data Capability

Data capability focuses on protecting and managing data by assessing its risk categories, establishing data classification, and implementing comprehensive data labeling. During data transmission, strong end-to-end encryption practices are essential to ensure robust encryption strength. Furthermore, continuous monitoring of data is necessary to ensure that data access is governed by robust access control mechanisms and to prevent any unauthorized data leaks. By adopting these measures, organizations can effectively safeguard their data and maintain a strong defense against potential data breaches.

E. Network & Environment Capability

The network & environment capability involves segmenting and isolating the network to enhance security. It can be broadly categorized into macrosegmentation and microsegmentation. Macrosegmentation is a commonly used network segmentation approach that utilizes virtual local area networks (VLANs) or subnets to logically separate different network areas, such as DMZ, management network, and internal network (which can be further subdivided based on task attributes).

Authorized licensed use limited to: Sheffield University. Downloaded on March 26,2026 at 05:53:57 UTC from IEEE Xplore. Restrictions apply.

In addition, microsegmentation allows for logical security segmentation of specific resource services, granting unique access control behavior for each segment. This approach is similar to the compartments in a submarine, where different isolated compartments prevent the entire submarine from sinking in case of compartment breach [18].

Microsegmentation is implemented to ensure the safety of individual services offered by an organization. By enforcing security boundaries, the probability of lateral movement or propagation of security breaches is minimized. Overall, both macrosegmentation and microsegmentation play critical roles in maintaining network security and protecting against potential cyber threats.

F. Automation & Orchestration Capability

Automation & orchestration is a critical aspect of the ZTA. It involves automating and orchestrating all security policies, procedures, and task coordination within the enterprise. By leveraging artificial intelligence (AI), complex and extensive management processes can be efficiently handled. Automation is employed to make decisions based on acquired intelligence, whether from external sources or internal learning, to prevent malicious actions and enforce corrective measures if necessary. This proactive approach ensures a swift response to potential threats and enhances the overall security posture by reducing human error and response time.

G. Visibility & Analytics Capability

In the face of vast amounts of data logs, relying on traditional manual methods for detecting malicious threats is no longer feasible. The integration of endpoint activities, device status, resource access, security logs, and other information must be analyzed to identify contextually relevant clues. AI and machine learning (ML) methods are utilized to build models and perform analyses. The results of these analyses can provide real-time improvement suggestions to decision-makers, enabling them to make informed decisions based on the identified threats and patterns of threat they face. This level of visibility and analytics enhances the overall security posture by detecting and responding to potential threats more effectively and efficiently.

In the U.S. Department of Defense's Zero Trust strategy [17], it clearly covers almost all aspects, these seven pillars ranging from user, devices, applications & workloads, data, network & environment, automation & orchestration, and visibility & analytics. We have depicted their potential scope in Fig. 4, which shows the defense aspects considered in the U.S. Department of Defense's Zero Trust Strategy covering all aspects of the security scope, including user authentication, device identification, and finally, automated management orchestration and security log AI/ML analysis. The implementation of these seven pillars is detailed in the Zero Trust Capability Execution Roadmap [19], which further elaborates on the execution activities within each pillar (comprising 91 basic activities and 61 advanced activities, totaling 152 activities to achieve all Zero Trust capabilities). The details provided in these documents can serve as an excellent entry point for enterprises looking to gradually adopt ZTA.

V. MITRE ATT&CK Matrix

MITRE ATT&CK [20] is a widely used information security framework. This framework is derived from real-world observations of adversaries, analyzing the attack tactics and techniques used by threat actors and state-backed hacking groups. Furthermore, MITRE provides mitigations and detection methods for each technique, all of which are freely accessible.

Based on the analysis of collected threat patterns and behaviors, the threat techniques are categorized into 14 tactics that can be distinguished, including reconnaissance, resource development, initial access, execution, persistence, privilege escalation, defense evasion, credential access, discovery, lateral movement, collection, command & control, exfiltration, and impact. Among these, reconnaissance and resource development fall outside the scope of enterprise defense and control. They are the preparatory actions (such as information gathering and development of hacking tools) taken by hackers before launching an attack. On the other hand, impact refers to the methods attackers adopt to achieve their goals against the target (victim). The remaining 11 tactics represent the main threats currently faced by enterprises.

In each tactic, detailed descriptions are provided on how adversaries implement their strategic goals through specific technical means with examples of their execution procedures. Enterprise security managers can utilize the MITRE ATT&CK Matrix to improve their recognition of attack patterns as well as behaviors, and enhance their ability to identify and respond to cybersecurity threats. Furthermore, they can use this information to address any deficiencies in software security development, understand common points of compromise by hacking groups, and select appropriate security management measures for their enterprise's cybersecurity environment to improve comprehensive security management.

For cybersecurity vendors, the design of cybersecurity defense models can be guided by information provided by the MITRE ATT&CK Matrix. This approach allows for precise identification of complete attack characteristics, which can then be used to create models using statistical analysis, AI or ML. By incorporating attack behavior patterns into these models, detection can be achieved effectively. Leveraging the information from MITRE ATT&CK matrix has helped cybersecurity professionals overcome the challenges of malicious behavior analysis, which typically require significant time and manpower resources. However, despite the richness of attack characteristics in these models, they have limitations due to the diverse and ever-changing nature of attacks. Hackers often modify their tactics to evade detection, making it difficult for enterprises to identify and respond to new attack variations. As a result, many enterprises have already fallen victim to attacks and intrusions even after incorporating insights from MITRE ATT&CK.

VI. Difficulties and Challenges

The purpose of a ZTA is to strengthen and continuously, albeit unpredictably, authenticate and authorize the behavior of a subject regarding resource access based on the analysis of environmental context. This significantly increases the difficulty for hackers to expand their lateral movement when attempting

Authorized licensed use limited to: Sheffield University. Downloaded on March 26,2026 at 05:53:57 UTC from IEEE Xplore. Restrictions apply.

to infect victims of a malicious attack. For attackers using tactics like spear-phishing, watering hole attacks, or drive-by-compromise methods to entice or designate victims to download custom-made malicious tools for account theft and lateral expansion, this approach can utilize enhanced and continuous verification and authorization methods to validate the abnormal behavior.

When dealing with externally downloaded programs that are not part of the system itself, the verification, authorization, and confirmation processes within the zero-trust framework can effectively detect these abnormal behaviors or processes. However, if these abnormal behaviors closely resemble normal ones, a significantly higher false positive rate can lead to increased difficulties in analysis.

In our previous paper [21], we also mentioned that these attack methods are often meticulously designed with the primary goal of simulating normal behavior patterns to effectively evade detection systems. Similar challenges appear in the manufacturing industry where manufacturers use both information technology and operational technology networks [22], [23], [24].

VII. Conclusion

The main goal of the ZTA is to establish a multilayered and continuously verified information security environment. Following the principle of "never trust, always verify," it ensures minimal resource access, eliminating implicit and inherited authorization to build a robust comprehensive enterprise security defense. This article references the NIST Special Publication 800-207 Zero Trust Architecture document to highlight the core elements of ZTA (PDP and PEP). It also presents strategies and a roadmap for implementing the ZTA.

While ZTA can mitigate certain attack vectors and is commonly referenced as part of the MITRE ATT&CK Matrix by security researchers, it is not a one-size-fits-all solution and cannot address issues involving seemingly normal but malicious or seemingly malicious but normal behavior. Moreover, blindly adopting the ZTA without careful consideration may involve complex technical requirements and necessitate changes in the organizational security culture. Therefore, enterprises must thoroughly understand and evaluate their existing information security defense frameworks and organizational security culture before adopting ZTA. By establishing sound internal cybersecurity practices and finding a ZTA approach that suits the specific needs of the organization, enterprises can construct a secure network environment.

References

[1] A. AI-Habaibeh, M. Watkins, K. Warked, and M. B. Javareshk, "Challenges and opportunities of remotely working from home during Covid-19 pandemic," *Glob. Transitions*, vol. 3, pp. 99–108, 2021.

[2] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," National Institute of Standards and Technology, Gaithersburg, MD. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-207

[3] Intel, "Trusted platform module (TPM) overview," [Online]. Available: https://www.intel.com.tw/content/www/tw/zh/business/enterprise-computers/resources/trusted-platform-module.html

[4] B. S. Radhika, N. V. Nagendra, and R. K. Shyamasundar, "Towards unifying RBAC with information flow control," in *Proc. 26th ACM Symp. Access Control Models Technol.*, 2021, pp. 45–54.

[5] S. Ameer, J. Benson, and R. Sandhu, "Hybrid approaches (ABAC and RBAC) toward secure access control in smart home IoT," *IEEE Trans. Dependable Secure Comput.*, vol. 20, no. 5, pp. 4032–4051, Sep./Oct. 2023.

[6] AWS Prescriptive Guidance, "Multi-tenant SaaS authorization and API access control," Aug. 2021. [Online]. Available: https://docs.aws.amazon.com/prescriptive-guidance/latest/saas-multitenant-api-access-authorization/welcome.html

[7] Y. Desmedt and A. Shaghaghi, "Function-based access control (FBAC): Towards preventing insider threats in organizations," in *From Database to Cyber Security*. New York, NY, USA: Springer, 2018, pp. 143–165.

[8] ISO, ISO/IEC 11889-1:2015, 2015. [Online]. Available: https://www.iso.org/standard/66510.html

[9] F. Okeke, "How to implement zero trust: Best practices and guidelines," Sep. 2023. [Online]. Available: https://www.techrepublic.com/article/how-to-implement-zero-trust/

[10] RSA Blog/Multi-Factor Authentication, "What is multi-factor authentication (MFA) and how does it work?," Oct. 2021. [Online]. Available: https://www.rsa.com/multi-factor-authentication/what-is-mfa/

[11] Fido Alliance, FIDO Authentication. [Online]. Available: https://fidoalliance.org/fido2/

[12] Google Identity, Authentication, Sep. 2023. [Online]. Available: https://developers.google.com/identity/passkeys?hl=en

[13] W. Stallings, *Network Security Essentials Applications and Standards*, 5th ed. London, U.K.: Pearson, 2014.

[14] M. Sabt, M. Achemlal, and A. Bouabdallah, "Trusted execution environment: What it is, and what it is not," in *Proc. IEEE Trustcom/BigDataSE/ISPA*, 2015, pp. 57–64.

[15] NIST Computer Security Resource Center, Post-Quantum Cryptography, Dec. 2023. [Online]. Available: https://csrc.nist.gov/Projects/post-quantum-cryptography/selected-algorithms-2022

[16] L. Daubner and A. Považanec, "Data loss prevention solution for linux endpoint devices," in *Proc. 18th Int. Conf. Availability, Rel. Secur.*, 2023, pp. 1–10.

[17] Chief Information Officer U.S. DoD., DoD Zero Trust Strategy, Nov. 2021. [Online]. Available: https://dodcio.defense.gov/Portals/0/Documents/Library/DoD-ZTStrategy.pdf

[18] Illumio, Microsegmentation. [Online]. Available: https://www.illumio.com/cybersecurity-101/microsegmentation

[19] Chief Information Officer U.S. DoD., DoD Zero Trust Capability Execution Roadmap (COA1), Nov. 2022. [Online]. Available: https://dodcio.defense.gov/Portals/0/Documents/Library/DoD-ZTExecutionRoadmap.pdf

[20] MITRE ATT&CK, MITRE Corporation. [Online]. Available: https://attack.mitre.org

[21] S. Shieh, S. Lee, and M. Tsai, "Strategy and tactics against ransomware," *IEEE Comput.*, vol. 55, no. 5, pp. 85–92, May 2022.

[22] SEMI E187-Specification for Cybersecurity of Fab Equipment, [Online]. Available: https://store-us.semi.org/products/e18700-semi-e187-specification-for-cybersecurity-of-fab-equipment

[23] L. Chang et al., SEMI E187 Reference Practice, Version 2.0, Oct. 2022. [Online]. Available: https://forms.office.com/Pages/ResponsePage.aspx?id=3QuozL10F0-Obe7NC6xaAujCICXu0vFEnfhFAXAhCNJUNzdWMDA5Rjc3U1ZUSktTUk1US1gySVVLVy4u

[24] J. Tu, S. W. Shieh, T. Liu, and L. Chang, "Cybersecurity reference architecture for semiconductor manufacturing environments," SEMI, pp. 1–28, 2023.

Authorized licensed use limited to: Sheffield University. Downloaded on March 26,2026 at 05:53:57 UTC from IEEE Xplore. Restrictions apply.